Tema 1 · Gestión de la Seguridad

SPD · Curso 2026/27 · Prof. Teodoro Rojo
Apuntes a partir de las diapositivas *SPD - 1. Gestión de la seguridad*. Las "Notas" son aclaraciones o ejemplos añadidos que no están literalmente en las diapositivas.

Índice

1. ¿Qué es la seguridad de la información?
2. Dimensiones de la seguridad
3. De la seguridad informática a la ciberseguridad
4. Principios básicos de la seguridad
5. La seguridad como proceso · SGSI
6. Marco normativo: ISO 27000, NIS/NIS2, ENS
7. Esquema general de la gestión de la seguridad
8. Fase 1 · Planificar y fijar objetivos (incluye análisis de riesgos)
9. Fase 2 · Definición de controles
10. Fase 3 · Monitorización y métricas
11. Otros modelos: NIST CSF, MITRE ATT&CK, ISM3, COBIT
12. Resumen final y grados de madurez
13. Preguntas de repaso

---

1. ¿Qué es la seguridad de la información?

Definición: protección **adecuada, proporcionada y razonable** de la información corporativa, que sea **eficaz** (consigue el objetivo) y **eficiente** (con un coste razonable), preservando:

- la **confidencialidad, integridad y disponibilidad** de la *información*, y
- la **integridad y disponibilidad** de los *recursos que la soportan* (sistemas, redes, personas…).

Nota: Idea clave: no se trata de proteger "todo al máximo", sino de proteger **en proporción al valor** de lo protegido y al riesgo. Gastar 100.000 € para proteger un activo que vale 1.000 € no es seguridad, es mala gestión.

---

2. Dimensiones de la seguridad

2.1 Las "3 + 1" dimensiones clásicas

Dimensión	Garantiza que…	Pregunta típica
Confidencialidad	La información **no esté disponible ni sea revelada** a personas, entidades o procesos **no autorizados**.	¿Quién puede *leerlo*?
Integridad	La información **no ha sido ni puede ser modificada** por personas, entidades o procesos no autorizados.	¿Alguien lo ha *cambiado*?
Disponibilidad	Los usuarios autorizados **tienen acceso** a la información y a sus activos **cuando lo necesitan**.	¿Está *accesible* cuando hace falta?

Dimensión	Garantiza que…	Pregunta típica
Trazabilidad (+1)	Se puede **hacer seguimiento de los cambios** que sufre la información.	*¿Quién hizo qué y cuándo?*

Nota: Truco: las tres primeras forman la tríada **CIA** (*Confidentiality*, *Integrity*, *Availability*).

2.2 Otros servicios / propiedades

- **Autentificación (autenticidad):** garantiza el **origen y destino** de la información intercambiada (la entidad es quien dice ser).
- **Imposibilidad de rechazo (no repudio):** evita que alguien niegue haber enviado/recibido algo, aportando una **prueba del intercambio**:
  - con **prueba de origen** (el emisor no puede negar que lo envió),
  - con **prueba de entrega** (el receptor no puede negar que lo recibió).
- **Control de acceso:** limita el acceso y uso de los recursos a los **usuarios autorizados**.

2.3 Dimensiones según el ENS

El **Esquema Nacional de Seguridad** usa **5 dimensiones** para valorar el impacto de un incidente y **categorizar el sistema**:

Sigla	Dimensión	Significado
[D]	Disponibilidad	—
[A]	Autenticidad	Una entidad es quien dice ser / se garantiza la fuente de los datos.
[I]	Integridad	—
[C]	Confidencialidad	—
[T]	Trazabilidad	Permite determinar **quién hizo qué y en qué momento**.

Nota: Regla nemotécnica: **"DAICT"**. Otras dimensiones propuestas en la literatura: **mantenibilidad** y **fiabilidad**.

2.4 El modelo de confianza (*dependability*)

En muchos sistemas el requisito de diseño más importante es la **confianza**: que el sistema **opere como se espera, libre de fallos**. Propiedades:

- Disponibilidad (corrección)
- Fiabilidad (continuidad)
- Seguridad en sentido pasivo (*safety*: accidentes, peligros)
- Confidencialidad
- Integridad
- Mantenibilidad

> "A computer is secure if you can depend on it and its software to behave as you expect" — Gene Spafford y Simson Garfinkel.

Nota: Ojo a la diferencia **security** (contra ataques intencionados) vs **safety** (contra accidentes/fallos que dañan personas o entorno). En español ambas se traducen como "seguridad".

---

3. De la seguridad informática a la ciberseguridad

Evolución conceptual (cada etapa amplía la anterior):

1. **Seguridad informática** → centrada en el **ordenador**: protegerlo contra robo o daño de hardware, software o datos.
2. **Seguridad en las TIC** → añade la **interconexión** entre sistemas; extiende la protección a las **infraestructuras de red**.
3. **Seguridad de la información** → la **información** es el elemento central. Es el término de los **estándares y normativas** (ISO 27000…).
4. **Ciberseguridad** → nuevas connotaciones: el **ciberespacio** como red global, el **componente humano** (usuarios) y la **evaluación continua**.

3.1 Definición de ciberseguridad (ITU-T X.1205)

Conjunto de herramientas, políticas, conceptos de seguridad, salvaguardas, directrices, métodos de gestión de riesgos, acciones, formación, prácticas idóneas, seguros y tecnologías **que pueden utilizarse para proteger los activos de la organización y los usuarios en el ciberentorno**.

- **Activos** = dispositivos conectados, usuarios, servicios/aplicaciones, sistemas de comunicaciones, comunicaciones multimedia y toda la información transmitida y/o almacenada.
- Propiedades a garantizar: **disponibilidad**, **integridad** (que puede incluir **autenticidad** y **no repudio**) y **confidencialidad**.
- El **ciberentorno** incluye el software, la información almacenada/transmitida/generada **y también las instalaciones y edificios** donde están los dispositivos.
- Se entiende como: (1) políticas y acciones para proteger las redes conectadas frente a acceso/modificación no autorizados, robo, interrupción…; y (2) **evaluación y supervisión constantes** de esas políticas, porque las amenazas cambian.
- La ciberseguridad también sirve para garantizar la **privacidad** y la **confianza** de los usuarios.

3.2 Definición de ISACA

Protección de activos de información, **a través del tratamiento de amenazas** que ponen en riesgo la información que es procesada, almacenada y transportada por los sistemas de información interconectados.

---

4. Principios básicos de la seguridad

Principio	Idea
Necesidad de conocer (*need-to-know*)	Cada usuario accede **solo** a la información y sistemas que **necesita para su función**.
Compartimentación	Se **clasifica** la información y las personas que pueden acceder a cada nivel.
Mínimo privilegio	Los permisos son los mínimos; **elevar un privilegio** es una operación **planificada y programada**.
Defensa en profundidad	**Múltiples capas** de seguridad para reducir el riesgo o minimizar el impacto.
Eslabón más débil	La medida de seguridad **más débil** condiciona la seguridad de todo el sistema.

Capas de la defensa en profundidad (de dentro hacia fuera, según la diapositiva): protección de la información sensible → suite de seguridad (antimalware…) → configuración robusta de equipos (*hardening*) → segmentación de redes y políticas de tránsito → seguridad perimetral (firewall, IDS…).

Nota: Ejemplo: aunque un atacante salte el firewall, se encuentra con la red segmentada; si entra en un equipo, este está bastionado; si llega a los datos, están cifrados.

Nota: Diferencia *need-to-know* vs *mínimo privilegio*: el primero habla de **qué información** ves; el segundo de **qué acciones/permisos** tienes sobre el sistema.

---

5. La seguridad como proceso · SGSI

> **"Security is a process, not a product"** — Bruce Schneier (*Secrets & Lies*).
> **"La seguridad no se improvisa, se gestiona."**

La seguridad **no** es una habilidad ni un conjunto de productos: es un **proceso de gestión sistemático, planificado, documentado y conocido por toda la organización**.

El proceso responde a cuatro preguntas (entrada → salida):

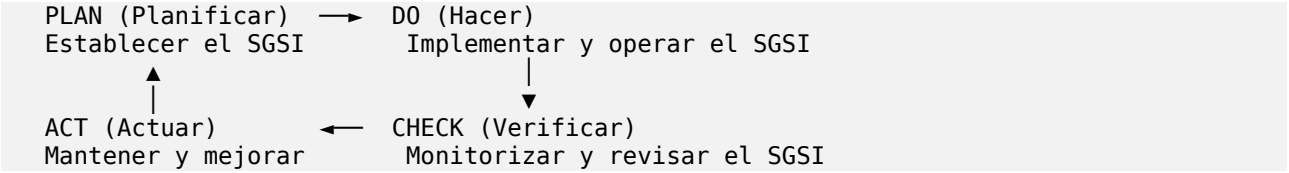
Pregunta	Se resuelve con
¿Dónde queremos estar?	Misión y objetivos de negocio
¿Dónde estamos hoy?	Evaluación
¿Cómo podemos llegar?	Cambios en el proceso
¿Cómo sabemos que hemos llegado?	Métricas

5.1 SGSI / ISMS

- **SGSI** (Sistema de Gestión de la Seguridad de la Información) = **ISMS** (*Information Security Management System*): conjunto de **políticas y procedimientos** para gestionar la seguridad **de forma sistemática**.
- **Objetivo: minimizar el riesgo** y **garantizar la continuidad del negocio**, limitando **de forma proactiva** el impacto de un incidente.

5.2 Ciclo PDCA (ciclo de Deming) — enfoque ISO 27000

El SGSI se basa en un ciclo **continuo**:



Nota: La clave es que **no termina nunca**: tras "Actuar" se vuelve a "Planificar" con lo aprendido (mejora continua).

---

6. Marco normativo

6.1 Panorama de marcos de referencia

Marco	Qué es
ISO/IEC 27001	Estándar internacional **certificable** para SGSI. Última versión **ISO/IEC 27001:2022**.
ENS	Esquema Nacional de Seguridad (España). RD 3/2010, revisado por **RD 311/2022**.
NIST CSF	*Cybersecurity Framework* (EE. UU.). **v2.0 (2024)**.
C2M2	*Cybersecurity Capability Maturity Model* (Dpto. de Energía EE. UU.), v2.1 (2022).
ISM3	*Information Security Management Maturity Model* (Fundación ISM3, 2007).
NIS2	Directiva europea de ciberseguridad (**UE 2022/2555**).
RGPD	Reglamento General de Protección de Datos (**UE 2016/679**). Ver anexo.

6.2 Familia ISO 27000 (anexo de las diapositivas)

Norma	Contenido
ISO 27000	Fundamentos y vocabulario
ISO 27001	**Especificación de un SGSI** (la **certificable**)
ISO 27002	**Código de buenas prácticas** (catálogo de controles, **no certificable**)
ISO 27003	Guía de implantación
ISO 27004	Métricas
ISO 27005	**Gestión de riesgos**
ISO 27006	Criterios de certificación (para las entidades certificadoras)
ISO 27007	Guía de auditoría

Nota: Pregunta típica: *¿Qué diferencia hay entre 27001 y 27002?* → 27001 dice **qué** debe tener el sistema de gestión y es **certificable**; 27002 explica **cómo** implantar los controles y **no** es certificable.

6.3 Directivas europeas NIS y NIS2

- **NIS** = *Network and Information Systems*. Objetivo: **elevado nivel común de ciberseguridad** en toda la UE y resiliencia de infraestructuras críticas.
- **NIS (UE 2016/1148)**: **primera** legislación de la UE en ciberseguridad.
- **NIS2 (UE 2022/2555)**: actualización; **entró en vigor el 16 de enero de 2023**.

Requisitos de NIS:

- Los Estados miembros adoptan **estrategias nacionales** de ciberseguridad.
- Operadores de **servicios esenciales** y **proveedores de servicios digitales** deben aplicar medidas de seguridad y **notificar incidentes graves**.
- Cada Estado crea **CSIRT** (*Computer Security Incident Response Team*) y una **autoridad nacional** de ciberseguridad.

Novedades de NIS2:

- **Más sectores** y categorías.
- Normas de seguridad **más estrictas** (gestión de riesgos, respuesta a incidentes).
- Notificación más clara y rápida: **primer aviso en 24 h**.
- **Sanciones más severas**, proporcionales (al estilo RGPD).
- Más cooperación: **mecanismo europeo de respuesta a crisis cibernéticas**.

Infraestructuras críticas: instalaciones, sistemas y servicios cuya interrupción tendría un **impacto significativo** en la sociedad, economía, seguridad o salud pública. En NIS eran los servicios esenciales (energía, transporte, salud, agua). NIS2 las divide en:

Essential Entities **(alta importancia)**	***Important Entities*** **(importantes)**
Energía (electricidad, petróleo, gas)	Servicios postales y mensajería
Transporte (aéreo, ferroviario, marítimo, carretera)	Fabricación de productos críticos (químicos, electrónicos, maquinaria)
Banca y mercados financieros	Gestión de residuos
Salud (hospitales, laboratorios, fármacos)	Alimentos y distribución
Agua (abastecimiento y residuales)	Servicios digitales (nube, plataformas online, CPD)
Infraestructuras digitales (CPD, DNS, telecos)	
Administración pública y defensa	

Obligaciones principales de NIS2:

1. **Medidas proporcionales al riesgo**: análisis de riesgos y políticas, gestión de incidentes, continuidad y recuperación, **seguridad en la cadena de suministro**, gestión de vulnerabilidades, formación.
2. **Notificación de incidentes: primer aviso ≤ 24 h** desde la detección; **informe final ≤ 72 h** con análisis de impacto y medidas.
3. **Gobierno y responsabilidad:** la **alta dirección** aprueba y supervisa las políticas, recibe formación y **responde** en caso de incumplimiento.

Atención: No confundir plazos: **NIS2 → 24 h (aviso) / 72 h (informe)**; **RGPD → 72 h** para notificar una brecha de datos personales.

6.4 Esquema Nacional de Seguridad (ENS)

- Obligatorio en el **ámbito gubernamental español desde 2010** (**RD 3/2010**; actualizado por **RD 311/2022**).
- **Objetivos:** crear confianza en el uso de medios electrónicos, establecer la política de seguridad, facilitar un tratamiento continuado de la seguridad.
- **Ámbito: Administraciones Públicas** y ciudadanos en sus relaciones con ellas; **se extiende a las empresas que prestan servicios a la Administración**.
- Reforzado con la entrada en vigor de **NIS2**.

Principios de seguridad del ENS:

Art.	Principio	Resumen
5	**Seguridad como proceso integral**	No solo actuaciones puntuales ni solo técnica: también aspectos humanos, organizativos, coordinación, formación.
6	**Gestión basada en los riesgos**	Metodología de análisis y gestión de riesgos; entorno con **riesgo aceptable**.
7	**Prevención, reacción y recuperación**	Medidas **disuasorias** (reducir exposición), **reactivas** (atajar incidentes) y **recuperativas** (restaurar cuanto antes).
8	**Líneas de defensa**	Defensa por capas: medidas **organizativas, físicas y lógicas**.
9	**Reevaluación periódica**	Las amenazas y riesgos cambian → actualizar medidas.
10	**Seguridad como función diferenciada**	Separar responsables: de la **información**, del **servicio** y de la **seguridad**.

Categorías de los sistemas (según el impacto de un incidente en la organización y en los derechos de los ciudadanos):

Categoría	Impacto
Alta	Daño **catastrófico / muy grave** (información clasificada, servicios esenciales, seguridad nacional). Medidas muy robustas.
Media	**Perjuicio grave** (p. ej. información personal y gran número de usuarios).
Básica (a veces "baja")	Perjuicio **limitado** (información rutinaria, pocos usuarios).

Nota: En las diapositivas aparece unas veces "baja" y otras "básica"; el término oficial del RD 311/2022 es **BÁSICA**.

Cómo adecuarse al ENS (ciclo de la diapositiva "Estructura y documentos"):

Paso	Guía CCN-STIC de apoyo
1. Preparar y aprobar la **política de seguridad**	805
2. **Definir roles** y asignar personas	801
3. **Valorar/categorizar** el sistema (información y servicios)	803
4. Realizar el **análisis de riesgos**	MAGERIT, PILAR, µPILAR
5. Preparar y aprobar la **declaración de aplicabilidad** (qué medidas aplican)	804, UNE ISO/IEC 27001 y 27002
6. **Implantar, operar y monitorizar** el sistema	806, 807, 811–814…
7. **Auditar cada dos años** (categorías media y alta)	802, 808
8. **Mejorar** la seguridad → vuelta al paso 1	809, 815

Documentación del ENS: guías **CCN-STIC** (Centro Criptológico Nacional), de **libre acceso**. La **CCN-STIC 804** es el **catálogo de medidas**: **71 medidas** clasificadas en:

- **[org]** Marco **organizativo**
- **[op]** Marco **operacional**
- **[mp]** Medidas de **protección**

…y para cada una se indica si aplica a categoría básica, media o alta.

Niveles de madurez del ENS (CCN-STIC-815, basados en **CMMI**):

Nivel	Nombre	Descripción
L0	Inexistente	—
L1	Inicial / *ad hoc*	Las salvaguardas existen pero **no se gestionan**.
L2	Reproducible pero intuitivo	La eficacia depende de la **buena suerte y buena voluntad** de las personas.
L3	Proceso definido	Salvaguardas desplegadas y gestionadas; **hay normativa y procedimientos**.
L4	Gestionado y medible	Se **evalúa** su eficacia y efectividad.
L5	Optimizado	Mejora continua, tecnológica e innovadora.

7. Esquema general de la gestión de la seguridad

7.1 Los tres pilares

Seguridad de la información = **Organización** + **Políticas, normas y procedimientos** + **Medidas técnicas**.

Nota: Si falla uno de los tres, el edificio se cae: la mejor tecnología no sirve sin procedimientos ni personas responsables.

7.2 El esquema en tres pasos ("mapa de situación")

```
1. FIJAR OBJETIVOS          2. DEFINIR CONTROLES        3. IMPLANTAR CONTROLES
   · Principios y objetivos    · Procedimientos            (y monitorizar)
   · Requisitos legales        · Organización
   · Política                  · Tecnología
   · Análisis de riesgos
```

Controles ≡ Salvaguardas ≡ Medidas ≡ Contramedidas (son sinónimos en este contexto).

8. Fase 1 · Planificar y fijar objetivos

Cuatro bloques encadenados: **Principios y objetivos de la organización → Marco legal/regulatorio/contractual → Política de seguridad → Análisis de riesgos.**

8.1 Principios y objetivos

> "La seguridad de la información debe estar **alineada con los objetivos y la cultura** de la organización."

Preguntas que hay que responder:

- ¿Hasta qué punto **dependemos** de los sistemas TI?
- ¿Qué **nivel de riesgo** podemos asumir?
- ¿**Quién** aceptará ese nivel de riesgo?

8.2 Marco legal, regulatorio y contractual

Tipo	Ejemplos
Legislación nacional	ENS, **LOPD-GDD**, **LSSI**, Firma electrónica, Acceso electrónico, Secretos oficiales…
Normativa internacional	NIS/NIS2, RGPD, **DORA**, Basilea III, Solvencia II, **SOX**, **PCI-DSS**
Estándares y buenas prácticas	ISO 27000, NIST, COBIT, ITIL
Acuerdos contractuales	**SLA** (*Service Level Agreements*)

Nota: DORA = reglamento europeo de resiliencia operativa digital del sector financiero; PCI-DSS = estándar de seguridad para quien procesa tarjetas de pago; SOX = ley Sarbanes-Oxley (EE. UU.), control interno financiero.

8.3 Política de seguridad

- **Documento de alto nivel** que recoge la **actitud y expectativas** de seguridad de la organización.
- Expresa la **conducta esperada**, las **reglas** y las **consecuencias del incumplimiento**.
- Es la **base** de toda la seguridad y debe ser **conocida por todos** los miembros.

Pirámide documental (de lo general a lo concreto):

Nivel	Contenido
Política	Declaración de intenciones de alto nivel. Alcance, objetivos, responsabilidades.
Planes	Situación de partida y meta; objetivos concretos y medios.
Procedimientos	Describen procesos: **qué, quién, cuándo, dónde**.
Tareas	Actividades específicas y **cómo** se realizan.
Registros y evidencias	**Pruebas objetivas** del estado de la seguridad.

Ejemplo de la diapositiva:

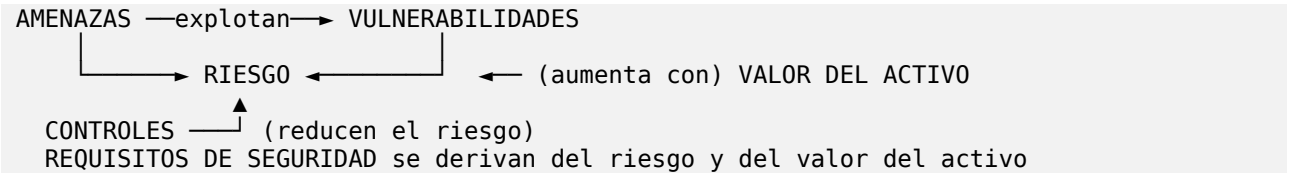
Política / Plan	Procedimiento	Tareas
Protección del servicio web	Actualización del software del servidor	Revisión **diaria** de parches del fabricante; seguimiento de noticias sobre fallos.
	Revisión de registros de actividad	Revisión **semanal** de *logs*; configurar **alertas** para reaccionar ante ataques.

8.4 Análisis de riesgos (importante) (muy importante)

Conceptos

- **Riesgo:** estimación del **grado de exposición** a que una **amenaza** se materialice sobre uno o más **activos** causando daños a la organización.
- **Análisis de riesgos:** proceso **sistemático** para **estimar la magnitud** de los riesgos. *Sabiendo lo que podría pasar, hay que tomar decisiones.*
- **Tratamiento de riesgos:** proceso para **modificar** el riesgo.
- **Activos:** recursos necesarios para que la organización funcione: información, servicios, aplicaciones, equipos, comunicaciones, recursos administrativos, físicos y humanos. **No todos valen lo mismo** → se valoran y protegen según su relevancia para el negocio.

Relación entre los elementos



Nota: Ejemplo: **activo** = servidor web; **vulnerabilidad** = Apache sin parchear; **amenaza** = atacante que explota un CVE conocido; **control** = política de parcheo semanal.

Definición formal y matriz de riesgo

> **Risk:** *the combination of the frequency, or probability of occurrence, and the consequence of a specified hazardous event* (IEC 60300-3-9:1995).

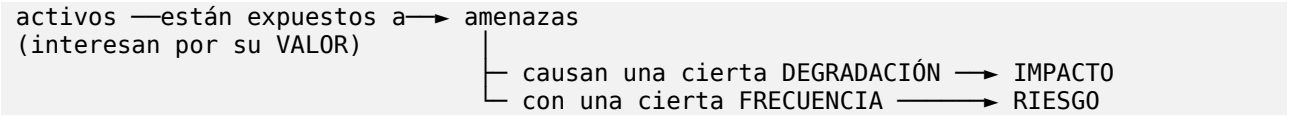
Simplificación: `Riesgo = Probabilidad × Impacto`

- **Matriz cualitativa:** escalas tipo *bajo / medio / alto* en ambos ejes.
- **Matriz cuantitativa:** valores numéricos (frecuencias anuales, €).

Nota: Ejemplo de matriz cualitativa 3×3:

Probabilidad \ Impacto	**Bajo**	**Medio**	**Alto**
Alta	Medio	Alto	**Crítico**
Media	Bajo	Medio	Alto
Baja	Bajo	Bajo	Medio

Modelo MAGERIT v3



- **Impacto** = valor del activo × degradación que causa la amenaza.
- **Riesgo** = impacto × frecuencia.

Con salvaguardas, todo pasa a ser **residual**: degradación residual → **impacto residual**; frecuencia residual → **riesgo residual**.

Nota: El **riesgo residual** es el que queda **después** de aplicar salvaguardas. Nunca es cero; la dirección debe **aceptarlo** formalmente.

Fases del análisis de riesgos

1. **Determinar los activos** relevantes, sus **dependencias** y su **valoración** (qué perjuicio supondría su degradación).
2. Determinar a qué **amenazas** están expuestos.

3. Estimar el **impacto** (daño sobre el activo si se materializa la amenaza).
4. Estimar el **riesgo** (impacto ponderado con la **tasa de ocurrencia**).
5. Determinar qué **salvaguardas** existen y **cuán eficaces** son.

Y en la práctica (diapositivas VIII–XIV), el proceso completo es:

Paso	Qué se hace
1. Identificación de activos y dependencias	Clasificación en **activos esenciales** (datos y servicios) y **de soporte** (HW, SW, redes, personas, instalaciones).
2. Valoración de activos	Valor **propio** o **acumulado** (el que hereda de los activos que dependen de él), en cada dimensión.
3. Caracterización de amenazas	Para cada activo: **frecuencia anual** e **impacto**.
4. Mapa de riesgos	Situar cada riesgo en la matriz.
5. Salvaguardas	Mitigar el riesgo → riesgo residual.
6. Plan de seguridad	Proyectos priorizados para reducir riesgos.

Dimensiones de valoración de un activo (preguntas MAGERIT):

Dimensión	Pregunta
Confidencialidad	¿Qué daño causaría que **lo conociera quien no debe**?
Integridad	¿Qué perjuicio causaría que estuviera **dañado o alterado**?
Disponibilidad	¿Qué perjuicio causaría **no tenerlo** o no poder usarlo?
Autenticidad	¿Qué perjuicio causaría **no saber exactamente quién hace** cada cosa?
Trazabilidad del servicio	¿**Quién hace qué y cuándo**?
Trazabilidad de los datos	¿Qué daño causaría **no saber quién accede a qué datos** y qué hace con ellos?

Nota: Valor acumulado: un servidor (activo de soporte) "vale" poco por sí mismo, pero si sobre él corre la base de datos de clientes (activo esencial), **acumula** el valor de esa información.

Metodologías

- **MAGERIT v3 (2012)** — española, del Ministerio (Portal de Administración Electrónica). Herramienta asociada: **PILAR** (CCN-CERT).
- **OCTAVE**, **CRAMM**, **COBRA**, … y la norma **ISO/IEC 27005**.

---

9. Fase 2 · Definición de controles

Control: cualquier **mecanismo o actividad** que **previene, detecta o corrige** errores o irregularidades. Ámbitos: organización, procedimientos, metodología del ciclo de vida de desarrollo, seguridad física y lógica.

9.1 Tipos de controles (importante)

Tipo	Objetivo	Ejemplos
Preventivo	**Evitar** que ocurra el suceso	Cortafuegos perimetral; filtrado de virus en la pasarela de correo
Detectivo	**Identificar** el suceso durante o después	IDS de red; firmas/hashes de archivos para detectar cambios
Disuasorio	**Desanimar** a quien quiera violar la política	Amenaza de despido; **bloqueo de cuenta tras N intentos fallidos**

Tipo	Objetivo	Ejemplos
Correctivo	**Remediar** lo que permitió el incidente o volver al estado anterior	Reconfigurar reglas del firewall; eliminar un virus y actualizar firmas
Recuperativo	**Restaurar** recursos y recuperarse de las pérdidas	**Copias de respaldo**; planes de continuidad y de recuperación ante desastres

Nota: Truco para el examen: ordénalos en el tiempo → **antes** (disuasorio, preventivo), **durante** (detectivo), **después** (correctivo, recuperativo).

9.2 Catálogo ISO/IEC 27002

- Es un **código de buenas prácticas** (**no certificable**).
- Incluye un **catálogo de controles** y una **guía de implantación**.
- Estructura: **Áreas/Dominios → Objetivos de control → Controles**.

Evolución:

Versión	Estructura
Antecedentes	BS 7799-1 e ISO/IEC 17799
ISO/IEC 27002:**2005**	**11** áreas, **39** objetivos, **133** controles
ISO/IEC 27002:**2013**	**14** áreas, **35** objetivos, **114** controles (en español: UNE-EN ISO/IEC 27002:2017)
ISO/IEC 27002:**2022**	**93** controles en **4 temas**: **organizacionales, de personas, físicos y tecnológicos**. Se añaden **11 nuevos**, muchos se fusionan y desaparece uno (integrado en el 7.10).

Dominios de la 27002:2005 (cláusulas 5–15): 5 Política de seguridad · 6 Organización de la seguridad · 7 Gestión de activos · 8 Seguridad en RR. HH. · 9 Seguridad física y del entorno · 10 Gestión de comunicaciones y operaciones · 11 Control de accesos · 12 Adquisición, desarrollo y mantenimiento de SI · 13 Gestión de incidentes · 14 Gestión de la continuidad del negocio · 15 Conformidad. Se agrupan en seguridad **organizativa, lógica, física y legal**.

Nota: Dominios de la 27002:2013 (cláusulas 5–18): 5 Políticas · 6 Organización · 7 RR. HH. · 8 Gestión de activos · 9 Control de acceso · 10 **Criptografía** · 11 Física y del entorno · 12 Seguridad de las operaciones · 13 Seguridad de las comunicaciones · 14 Adquisición, desarrollo y mantenimiento · 15 **Relación con proveedores** · 16 Gestión de incidentes · 17 Continuidad · 18 Cumplimiento.

Nota: 27002:2022 — 4 temas (cláusulas 5–8): **5 Organizacionales (37)**, **6 Personas (8)**, **7 Físicos (14)**, **8 Tecnológicos (34)** → 37+8+14+34 = **93**.

Ejemplos de las diapositivas. El título indica el número del control en **2013 (2005) (2022)**: el mismo control cambia de número en cada versión. Cada control de la norma tiene la misma estructura: **Objetivo → Control → Guía de implantación → Otra información.**

Ejemplo 1 · 8.2.1 *Classification of information* (dominio 8 *Asset management*, objetivo 8.2 *Information classification*)

- **Objetivo:** que la información reciba un **nivel de protección adecuado a su importancia** para la organización.
- **Control:** clasificar la información según **requisitos legales, valor, criticidad y sensibilidad** frente a revelación o modificación no autorizadas.
- **Guía:** la clasificación tiene en cuenta las necesidades del negocio de compartir o restringir; otros activos se clasifican según la información que contienen o procesan; **los propietarios** de los activos son **responsables** de su clasificación; el esquema debe ser **coherente en toda la organización**, alineado con la política de control de acceso, y **revisarse** a lo largo del ciclo de vida.

- **Otra información:** la información puede **dejar de ser sensible** (p. ej. al hacerse pública). **Sobreclasificar** → controles innecesarios y gasto; **infraclasificar** → pone en riesgo los objetivos de negocio.
- **Ejemplo de esquema de confidencialidad con 4 niveles:** (a) su revelación **no causa daño**; (b) causa **molestias leves**; (c) **impacto significativo a corto plazo** en operaciones; (d) **impacto grave a largo plazo** o pone en riesgo la **supervivencia** de la organización.

Ejemplo 2 · 9.4.5 *Access control to program source code* (dominio 9 *Access control*, objetivo 9.4 *System and application access control*: evitar accesos no autorizados a sistemas y aplicaciones)

- **Control:** el acceso al **código fuente debe estar restringido**.
- **Por qué:** evitar funcionalidades no autorizadas, cambios no intencionados y proteger la **propiedad intelectual**. Se consigue con un **almacenamiento central controlado** (librerías de código fuente).
- **Pautas:** (a) no guardar las librerías de código en **sistemas en producción**; (b) gestionarlas según procedimientos; (c) el **personal de soporte** no debe tener acceso sin restricciones; (d) actualizar o entregar código **solo con autorización**; (e) listados en entorno seguro; (f) **registro de auditoría** de todos los accesos; (g) mantenimiento y copia sujetos a **control de cambios**.

Nota: Ojo: en la ISO 27002:2022 el acceso al código fuente es el **8.4** ✓, pero "clasificación de la información" es el **5.12** (el 5.35 es "revisión independiente de la seguridad"). Si te lo preguntan, comprueba con el profesor qué numeración quiere.

9.3 Controles del ENS

CCN-STIC 804: guía de implantación con **71 medidas** clasificadas en **[org]** organizativas, **[op]** operacionales y **[mp]** de protección, indicando su aplicabilidad según la categoría (básica/media/alta). Ver también la guía de gobernanza del ENS navegable del CCN-CERT.

---

10. Fase 3 · Monitorización y métricas

Hay que definir **métricas e indicadores** para:

- Comprobar la **evolución de los objetivos** de seguridad.
- Medir el **grado de implantación y eficacia** de los controles.
- Detectar **necesidades de mejora** y corregir desviaciones.

→ **Conocer el estado y la evolución de la seguridad.** Ciclo: **definir → medir → mejorar**.

Ejemplos de métricas:

Control	Guía de implantación	Métrica
8.1.2 Selección (RR. HH.)	Verificar antecedentes de los candidatos en proporción a la información a la que accederán	**% de nuevos empleados** totalmente verificados **antes** de empezar
10.5 Copias de seguridad	Procedimientos de backup y recuperación; estrategia; **cifrar** backups con datos sensibles	% de backups/recuperaciones de prueba **exitosas**; **tiempo medio** desde recoger el soporte externo hasta recuperar los datos; % de backups sensibles **cifrados**

Cuadro de mandos de seguridad

Herramientas **SIM / SIEM** (*Security Information Management / Security Event Information Management*): recogen **vulnerabilidades, parches, eventos, logs, activos, controles e información manual** y generan **indicadores** y **alertas** de seguridad, comparando la evolución con una **meta**.

Nota: Ejemplos de SIEM reales: Splunk, Wazuh, Elastic Security, Microsoft Sentinel.

11. Otros modelos

Modelo	Qué es
NIST CSF v2.0 (2024)	Marco de gestión de la seguridad del NIST. **6 funciones**: **Gobernar**, Identificar, Proteger, Detectar, Responder y Recuperar. (La v1 tenía 5; **Gobernar** es la novedad de la v2.)
MITRE ATT&CK	**Base de conocimiento** global de **tácticas y técnicas** de los atacantes, basada en observaciones reales. Sirve para modelar, detectar, prevenir y combatir amenazas. Tiene varias **matrices** (Enterprise, Mobile, ICS).
ISM3	Modelo de madurez de gestión de seguridad **basado en procesos**; suele implantarse en entornos gestionados con **ITIL**.
COBIT	*Control Objectives for Information and related Technology*. Marco y guía de buenas prácticas de **gestión de TI**, mantenido por **ISACA**.

Nota: Nemotecnia NIST CSF 2.0: **"GIPDRR"** → Gobernar, Identificar, Proteger, Detectar, Responder, Recuperar.

12. Resumen final

12.1 Marco normativo de un vistazo

Bloque	Normas	Qué aporta
Análisis de riesgo	MAGERIT v3, ISO/IEC 27005, OCTAVE, CRAMM	Inventario de activos, determinación del riesgo, selección de controles
Controles de seguridad	ISO/IEC 27002, CCN-STIC 804	Códigos de buenas prácticas; implantar y verificar controles
Sistema de gestión (SGSI)	BS 7799-2:2001, UNE 71502:2004, **ISO/IEC 27001**	Política, metodología de riesgos y métricas, gestión de actividades. **CERTIFICABLE**

12.2 Grados de madurez de una organización

1. **Medidas básicas por "sentido común"** — backup, control de acceso…
2. **Cumplimiento de la legislación** — RGPD/LOPD, LSSI, delitos informáticos…
3. **Gestión global de la seguridad** — políticas, planes, procedimientos, riesgos, **plan de respuesta a incidentes**.
4. **Certificación** de la gestión de seguridad — **confianza y verificabilidad por terceros**.

12.3 Organismos y recursos útiles

- **INCIBE** (Instituto Nacional de Ciberseguridad) · **CCN / CCN-CERT** (Centro Criptológico Nacional) · Portal ISO 27000 en español · **PILAR** (herramienta de análisis de riesgos).

13. Preguntas de repaso

1. Define las cuatro dimensiones "3+1" y pon un ejemplo de ataque contra cada una.
2. ¿Cuáles son las 5 dimensiones del ENS? ¿Qué añade respecto a la tríada CIA?
3. Diferencia entre *need-to-know*, compartimentación y mínimo privilegio.
4. Explica la defensa en profundidad y el principio del eslabón más débil con un ejemplo.
5. ¿Qué es un SGSI y en qué ciclo se basa? Describe cada fase del PDCA.

6. ¿Qué diferencia hay entre ISO 27001, 27002 y 27005?
7. Plazos de notificación en NIS2 y en RGPD.
8. *Essential* vs *Important Entities* en NIS2: pon 3 ejemplos de cada.
9. Enumera los principios del ENS (arts. 5–10).
10. Categorías del ENS y niveles de madurez L0–L5.
11. Define riesgo, amenaza, vulnerabilidad, activo, impacto y salvaguarda, y relaciónalos.
12. ¿Qué es el riesgo residual? ¿Quién lo acepta?
13. Fases del análisis de riesgos según MAGERIT.
14. Clasifica: *bloqueo de cuenta tras 3 intentos*, *IDS*, *backup*, *firewall*, *reinstalar desde imagen limpia*.
    Solución: Disuasorio · Detectivo · Recuperativo · Preventivo · Correctivo
15. ¿Cómo ha cambiado la estructura de la ISO 27002 entre 2005, 2013 y 2022?
16. ¿Qué es un SIEM y para qué sirve en la fase de monitorización?
17. Funciones del NIST CSF 2.0.

Referencias

- MAGERIT v3 — administracionelectronica.gob.es
- PILAR — pilar.ccn-cert.cni.es
- INCIBE — incibe.es · CCN — ccn.cni.es
- Portal ISO 27000 en español — iso27000.es
- CCN-STIC-804 (medidas de implantación del ENS) y CCN-STIC-805 (política de seguridad)